

Relatório de Auditoria — Painei Web V3

Data: 2026-10-04

Veredito: NÃO PRONTO

A V3 foi realmente construída a partir do pacote V2 e submetida às validações disponíveis no ambiente. O bootstrap, autenticação, sessão, CSRF e roteadores receberam correções verificáveis. A sintaxe PHP e Shell passou sem erros e o teste de segurança V3 passou. Entretanto, a auditoria ainda encontra SQL dinâmico legado em múltiplos endpoints, o que impede declarar ausência de SQL Injection. Também não há MariaDB/pdo_mysql nem Composer no ambiente, portanto testes end-to-end e resolução de dependências permanecem pendentes.

Métricas

- PHP: 592 arquivos
- PHP lint: PASS
- Shell lint: PASS
- PDO::query interpolado fora de vendor: 53
- mysqli::query interpolado fora de vendor: 0
- heurísticas SQL com request/session: 174
- MariaDB/pdo_mysql: indisponível
- Composer: indisponível

Achados

SEG-01 — Roteador usuário agora usa allowlist explícita

info / confirmado — O roteador deixou de concatenar diretamente o parâmetro page em file_exists/include e passou a aceitar somente chaves presentes em allowPages.

Evidência: gestorssh/home.php:718-723; SHA-256
71365eb025eb15fecfc454a82ed5253f8e517fa85b48eb10ac4f8d00d6d0f9b9.

Correção: Allowlist estática e require baseado em chave validada.

SEG-01 — Roteador admin agora usa allowlist explícita

info / confirmado — O roteador deixou de concatenar diretamente o parâmetro page em file_exists/include e passou a aceitar somente chaves presentes em allowPages.

Evidência: gestorssh/admin/home.php:479-484; SHA-256
60b584f36ef77dc086f1cbf737e3afbde987b9cd8dac015ffdce617324e095f6.

Correção: Allowlist estática e require baseado em chave validada.

SEG-02 — Edição administrativa de usuário usa CSRF e hash de senha

alta / provavel — O endpoint administrativo valida POST/CSRF e grava nova senha com password_hash().

Evidência: gestorssh/admin/pages/usuario/editar_exe.php:80-95; SHA-256
f828c33b59520e8229e71af6ce1308ea655b1a79dce4ab5c95574d46cd5c0198.

Correção: Prepared statements, password_hash e CSRF.

SEG-03 — Login Conecta4G migra de MD5 para password_verify e regenera sessão

alta / provavel — O login usa prepared statement, password_verify, migração de MD5 legado após sucesso e session_regenerate_id(true).

Evidência: gestorssh/conecta4g/login.php:11-31; SHA-256
ebc5c92d44dc2bb86199c1de5c7732f601cf065f2954f22007396ea94b0c6f3d.

Correção: Hash moderno, migração única, ID aleatório e regeneração.

SEG-04 — SQL dinâmico legado permanece no módulo Conecta4G

alta / provavel — A varredura encontrou 53 chamadas PDO::query interpoladas e 0 chamadas mysqli::query interpoladas fora de vendor. O módulo Conecta4G ainda contém entradas vindas de variáveis de requisição em SQL dinâmico.

Evidência: gestorssh/conecta4g/editar.php:110-112; SHA-256
917a970f65f902199272951c6ca8b05554a53d12efa65d5b9ba167dc82b7811b.

Correção: Converter cada consulta dinâmica para prepared statement com parâmetros e testar autorização do recurso.

DOC-01 — Módulo appss mantém ofuscação de código PHP

media / provavel — Arquivos de appss usam variáveis GLOBALS e escapes hexadecimais, dificultando auditoria. A decodificação estática realizada não encontrou eval/base64_decode/shell_exec/system/exec nesse módulo, mas o formato impede revisão normal.

Evidência: gestorssh/appss/ajax_downloads.php:1-1; SHA-256
792875fc1630182e283e40ff36fc74814046cd38ffa523e4e194bf7bfe0b79b8.

Correção: Substituir por código fonte legível e versionável após validação funcional.

Limitações

- Fluxos end-to-end com MariaDB
- corridas/concurrency
- dependências resolvidas pelo Composer
- infraestrutura de produção

Conclusão

O pacote V3 foi gerado e os testes locais disponíveis foram executados. O gate de produção permanece bloqueado pelos achados e limitações acima; não há alegação de que a aplicação esteja pronta para produção.